Desarrollo de Software Seguro
Presentación en Clase: SANS Top 25 + OWASP Top 10

Presentación en Clase

"Me lo contaron y lo olvidé, lo vi y lo entendí, lo hice y lo aprendí" - Confucio

Introducción y contexto

Una parte importante en el proceso de aprendizaje es adquirir la capacidad de comunicar conocimiento tanto a pares como a otros interesados.
El objetivo de esta actividad es que cada estudiante (de forma individual o en pareja de distintas clases) presente un ítem del OWASP Top 10 (Web) o el SANS Top 25.

Presentación

Cada estudiante debe crear una presentación sobre el ítem que se le fue asignado.
La presentación debe poseer por lo menos:

- Presentación teórica del ítem
- Ejemplo práctico (demo en vivo)
- Cómo se mitiga.
- Responder preguntas.

Los puntos a ser presentados por los estudiantes serán los siguientes:

Sans Top 25 (https://cwe.mitre.org/top25/archive/2025/2025_cwe_top25.html):

- 2 CWE-89 - Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')
- 3 CWE-352 - Cross-Site Request Forgery (CSRF)
- 4 CWE-862 - Missing Authorization
- 5 CWE-787 - Out-of-bounds Write
- 6 CWE-22 - Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')
- 9 CWE-78 - Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')
- 10 CWE-94 - Improper Control of Generation of Code ('Code Injection')
- 11 CWE-120 - Buffer Copy without Checking Size of Input ('Classic Buffer Overflow')
- 12 CWE-434 - Unrestricted Upload of File with Dangerous Type
- 15 CWE-502 - Deserialization of Untrusted Data
- 17 CWE-863 - Incorrect Authorization
- 18 CWE-20 - Improper Input Validation
- 19 CWE-284 - Improper Access Control
- 20 CWE-200 - Exposure of Sensitive Information to an Unauthorized Actor
- 21 CWE-306 - Missing Authentication for Critical Function

- 22 CWE-918 - Server-Side Request Forgery (SSRF)
- 23 CWE-77 - Improper Neutralization of Special Elements used in a Command ('Command Injection')
- 24 CWE-639 - Authorization Bypass Through User-Controlled Key
- 25 CWE-770 - Allocation of Resources Without Limits or Throttling

OWASP Top 10 Web Application Security Risk 2025 (https://owasp.org/Top10/2025/):

- A01 Broken Access Control
- A02 Security Misconfiguration
- A03 Software Supply Chain Failures
- A04 Cryptographic Failures
- A05 Injection
- A06 Insecure Design
- A07 Authentication Failures
- A08 Software or Data Integrity Failures
- A09 Security Logging and Alerting Failures
- A10 Mishandling of Exceptional Conditions

Equipos

Se sortearán equipos para la realización de cada punto. Los equipos estarán conformados por 2 (dos) estudiantes de distintas clases de la misma cohorte. Ambos estudiantes deben de poder exponer completamente el ítem que les fue asignado, de forma que, si se encuentran en la clase unitaria o en la cohorte, se pueda exponer el punto cabalmente.

Entregables

I. Presentación en formato preestablecido
II. Ejemplo práctico (fuentes)
III. Deben entregar un instructivo de cómo reproducir la demo

El tiempo máximo de exposición es de 15 minutos.

Evaluación

El trabajo entregado será evaluado considerando los siguientes aspectos:

- Profundidad y detalle.
- Completitud.
- Presentación.
- Comprensión de la temática.